

Penetration Testing Scope of Work (SOW)

Project Overview

This document defines the scope, objectives, and guidelines for the penetration testing engagement focused on identifying critical security flaws within the Zero Health System Infrastructure. The test is aimed at validating system hardening and determining the exposure level of services such as Apache HTTPD, Samba, OpenSSH, and NFS.

The penetration testing team will focus on assessing the following potential threats and impact areas:

- Account takeover due to weak authentication mechanisms
- Client-side attacks, such as manipulation of outdated Apache servers
- Server-side exploitation including known CVEs like **CVE-2017-7494 (ETERNALRED)** and **CVE-2001-0912**
- Privilege escalation through poorly configured Samba and SSH services
- Fraudulent access or unauthorized file sharing
- Gaining administrator or root-level access through vulnerable network daemons
- If applicable, prompt injection or misconfigured AI-related endpoints will be reviewed

Scope Definition

- Target System: Zero_Health_Internal_Network (192.168.88.27)
- Allowed Ports: All identified open ports during reconnaissance (e.g., 22, 80, 111, 139, 443, 32768)

In-Scope Activities:

- Network mapping and port scanning to identify exposed services
- Banner grabbing, service enumeration, and version identification
- Manual and automated vulnerability analysis using tools such as Nmap, Nikto, and Metasploit
- Proof-of-concept exploitation of confirmed vulnerabilities including Apache Path Disclosure, OpenSSH buffer issues, and Samba remote code execution
- Report compilation and documentation of attack vectors and system weaknesses

Out-of-Scope Activities:

- Execution of actual Denial-of-Service (DoS) payloads against production
- Exploitation of external-facing systems not defined in scope
- Permanent modification, deletion, or exfiltration of real organizational data

Testing Methodology

This penetration test will follow industry-standard methodologies and a hybrid manual-automated approach:

- **OWASP Testing Guide v4:** for web-based assessments
- **NIST SP 800-115:** for technical and procedural testing guidelines
- **Penetration Testing Execution Standard (PTES):** for structure, exploitation, and post-exploitation phases
- Realistic emulation of attacker behaviour without causing damage.

Ethical & Legal Considerations

All activities will be conducted within a controlled, ethical framework. The testing team commits to:

- Avoid disrupting business-critical services or causing downtime
- Maintaining data integrity and confidentiality throughout the assessment
- Staying strictly within the agreed scope of testing
- Complying with Nigerian cyber laws and Zero Health's internal IT security policies

Reporting and deliverables

Upon project completion, the penetration testing team will deliver a comprehensive report that includes:

- Executive summary for management
- Technical documentation of findings categorized by severity (CVSS-based)
- Screenshots or output of successful PoC exploits (e.g., Samba RCE, Apache info leak)
- Recommended mitigation and remediation strategies
- Verification checklist and proposed roadmap for patching

Timeline

- **Start Date:** 20/06/2025
- **End Date:** 25/06/2025
- **Report Submission Deadline:** 26/06/2025

Point of Contact

- **Project Lead:** Onaopemipo Olugbemiro
- **Security Team Contact:** Onaopemipo Olugbemiro
- **Participant Supervisor:** Oluwatobi Okafor

Authorization & Acknowledgement

All testing activities and findings are confidential and bound by ethical disclosure rules. All testers will follow strict responsible disclosure practices and must not share or publish discovered vulnerabilities outside the authorized reporting channels without prior written approval.

By signing below, the involved parties acknowledge and agree to the terms outlined in this document.

Authorized by

Name: Oluwatobi Okafor

Role: Chief Information Security Officer

Date: 19/06/2025